

RETELE DE CALCULATOARE

Cursul nr. 9

Concepte de
securitate în
rețelele de
comunicații

CUPRINS

- Concepte de bază
- Instrumente
- Tipuri de atacuri
- Sisteme de tip IDS/ IPS
- Firewall-uri
- Criptografie
- Mecanism autentificare site web
- Securizare dispozitive Cisco

CONCEPTE DE BAZĂ

- Amenințare IT
 - Cu potențial de afectare a unui element dintr-o rețea
- Vulnerabilitate
 - Slăbiciune a unui element dintr-o rețea
- Exploatare a unei vulnerabilități (exploit)
 - Utilizare a unei vulnerabilități pentru a compromite un element dintr-o rețea
- Risc
 - Probabilitatea ca o exploatare a unei vulnerabilități să aibă succes
- Plan/ acțiuni de mitigare
 - Acțiunile de evitare/ eliminare a riscurilor

INSTRUMENTE PENTRU HACKING

■ Instrumente pentru hacking

- Utilizate de hackeri, inclusiv de către white hackers pentru a găsi vulnerabilități
- Rulează, în general, pe sisteme de tip GNU/Linux
 - Kali Linux – distribuție de GNU/Linux axată pe tooluri de pentesting/ hacking
- Instrumente de spart parole
- Instrumente de interceptat traficul din rețele
- Instrumente pentru scanarea
 - IP-urilor (*ping sweeper*)
 - porturilor și vulnerabilităților (*ex: nmap*)

ATACURI ȚINTITE VS ATACURI CU ȚINTE ALEATORII

- Atacurile pot viza anumite ținte: o persoană/ organizație anume

-> **atacuri țintite**

- mai rare

sau

- pot căuta să exploateze vulnerabilități la orice elemente din Internet (PC-uri personale, din orice organizații, nu neapărat dintr-o organizație anume sau ale unor anumiți utilizatori) -> **cu ținte aleatorii**

- cele mai frecvente

- Utilizează instrumente care scanează în masă sisteme (porturi, vulnerabilități) și atacă oriunde se identifică vulnerabilitatea vizată

ATACURI ȚINTITE

■ Pași

- Studierea țintei din exterior pentru obținerea de informații care pot fi utilizate pentru atac
 - Tehnici non-intruzive precum căutarea informațiilor publice
 - Tehnici mai avansate bazate pe informațiile publice identificate ca vulnerabilități care pot fi exploatare
- Compromiterea unui element din sistemul vizat
- Escalarea privilegiilor
- Studierea țintei din interior
- Escalarea compromiterii țintei
- Atingerea scopului atacului: acces la anumite date, compromiterea unui sistem, etc.

SOCIAL ENGINEERING

- ~ Inginerie socială
- Tehnici de identificare a informațiilor publice care pot fi utilizate pentru lansarea de atacuri
- Phishing: un tip de atac care poate fi bazat pe social engineering

MALWARE

Malware – orice software malițios:

- **Viruși**
- **Viermi**
 - Software care se inserează în alt software; se poate transmite între aplicații/ diferite gazde (aplicații de pe aceeași stație/ stații diferite)
- **Cai troieni**
 - Software malițios livrat împreună cu/ sub forma de software util
 - Adesea instalează „back doors”
 - Back doors - Căi ascunse de acces pe un sistem (ascunse de utilizatorul legitim)
- **Ransomware (software pentru recompense)**
 - În general, criptează datele gazdei infestate și cere o recompensă pentru a furniza cheia de decriptare

PHISHING

- Solicitarea de informații private care pot fi utilizate pentru diferite atacuri de către atacatori care pretind că sunt o entitate cu acces justificat la datele respective
- Exemple:
 - Mail-uri transmise la baze de date cu adrese de email care pretind de la destinatari introducerea datelor referitoare la
 - Carduri bancare
 - Date de autentificare pe diferite sisteme
 - Alte date personale care pot fi exploatare
- Adeseori se bazează atât pe
 - **pretinderea unei false identități**
 - cât și pe **crearea de site-uri web care copiază identitatea vizuală** a entităților cu acces justificat la datele solicitate

MĂSURI DE PROTECȚIE ANTI MALWARE ȘI ANTI PHISHING

- Instalarea de software antimalware – antivirus
 - Pe stații
- Configurarea de politici de securitate care să:
 - împiedice utilizatorii să oprească antivirusul
 - împiedice utilizatorii să acceseze site-uri periculoase, de ex. fără certificat
 - să nu transmită/ scoată din organizație informații sensibile
- Sisteme IPS pot fi utilizate pentru a bloca traficul care conține malware
- Utilizarea de software care filtrează mesajele email
- Utilizarea de software care scanează atașamentele mesajelor email
- Educarea angajaților cu privire la tipuri de atacuri și politici de securitate

ATACURI DE TIP DoS

- Denial of Service
- Atacuri bazate pe inundarea unui sistem cu un volum mare de trafic astfel încât acesta nu mai poate furniza serviciile uzuale
- Pot fi oprite prin blocarea traficului de la sursa care a pornit atacul

ATACURI DE TIP DDoS

- Distributed Denial of Service
- Atacuri de tip DoS care vin din surse diferite
 - Sursele atacurilor sunt, în general, dispozitive compromise: infectate cu malware de tip viruși/ troieni sau dispozitive cu politici de securitate slabe care sunt controlate de atacator să transmită mult trafic către țintă
- Mai dificil de oprit decât DoS

MĂSURI DE PROTECȚIE ANTI DoS ȘI DDoS

- Utilizarea de sisteme IPS
- Utilizarea unui firewall
- Blocarea conexiunilor care pot constitui un atac de tip DoD sau DDoS prin firewall, fără a bloca resursa vizată
- Există soluții de servicii anti DDoS precum NETSCOUT – monitorizează traficul din Internet pentru detecția rețelelor de tip botnets și a centrelor de control pentru acestea
- Distribuția geografică a resurselor organizației și redundanța în infrastructură pot ajuta

ATACURI BAZATE PE SPOOFING

- Spoofing - falsificare
- IP address spoofing
 - Atacatorul pretinde că are o adresă IP care trece de diferite reguli firewall
- MAC address spoofing
- Falsificarea unei aplicații: de ex. un server DHCP

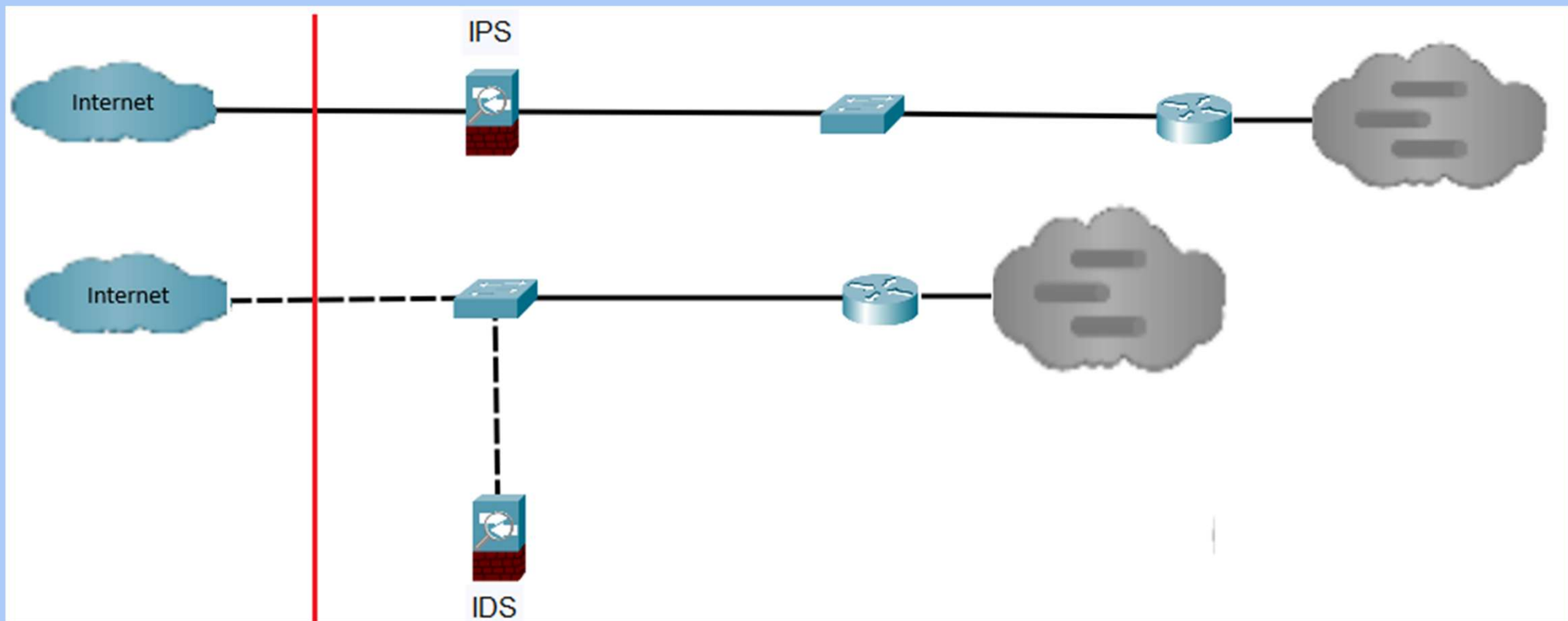
MĂSURI DE PROTECȚIE ANTI MALWARE ȘI ANTI PHISHING

- Instalarea de software antimalware – antivirus
 - Pe stații
- Configurarea de politici de securitate care să:
 - împiedice utilizatorii să oprească antivirusul
 - împiedice utilizatorii să acceseze site-uri periculoase, de ex. fără certificat
- Sisteme IPS pot fi utilizate pentru a bloca traficul care conține malware
- Utilizarea de software care filtrează mesajele email
- Utilizarea de software care scanează atașamentele mesajelor email
- Educarea angajaților cu privire la tipuri de atacuri și politici de securitate

SISTEME IDS/ IPS

- Sisteme de detecție/ prevenție a intruziunilor
 - **Intrusion Detection Systems**
 - → în principiu nu blochează atacurile, transmit informații despre tentative către administratori sau direct către un sistem de firewall care poate bloca atacurile
 - **Intrusion Prevention Systems**
 - → poate bloca atacuri
- Sisteme care pot analiza pachetele (complet, până la nivelul 7 - Aplicație) pentru a identifica traficul care poate reprezenta tentative de atac
 - Se verifică cu pattern-uri deja știute pentru atacuri
 - Pattern-urile pot fi diferite în funcție de traficul uzual din rețeaua unei organizații
 - Sistemele trebuie adaptate rețelei în care funcționează
 - Este necesar personal de administrare priceput

SISTEME IDS/ IPS



FIREWALLS VS IPS/IDS

- Sistemele IPS/ IDS inspectează traficul (conținutul pachetelor la toate nivelurile stivei OSI; patternuri la nivel de pachet și la nivel de comunicații, grupuri de pachete) și caută patternuri care corespund unor atacuri
 - Caută semnături de atacuri
 - Pot lipsi în rețeaua unei organizații. Adesea vin în completarea unui firewall
- Sistemele firewall permit/ blochează traficul **pe baza unor reguli predefinite**
 - Sunt nelipsite în infrastructura unei organizații
 - La limita rețelei organizației cu Internetul (legătura cu ISP-ul)
 - Opțional, și înaintea unor resurse cu acces controlat

FIREWALLS

- Sistemele firewall permit/ blochează traficul **pe baza unor reguli predefinite**
 - Sunt nelipsite în infrastructura unei organizații
 - La limita rețelei organizației cu Internetul (legătura cu ISP-ul)
 - Opțional, și înaintea unor resurse cu acces controlat
 - În dispozitivele moderne, dispozitivele dedicate de firewall integrează și funcțiile sistemelor de tip IPS
 - Dispozitive moderne de la Cisco: ASA – **Adaptive Security Appliance**

STATEFUL FIREWALLS

- Firewall-ul permite traficul pe baza conexiunilor deja stabilite
 - Menține evidența conexiunilor existente
- De exemplu:
 - Firewall-ul are regula stabilită de a nu permite trafic din exterior
 - O stație din interior stabilește o conexiune cu un IP din exterior
 - Traficul de la stația din exterior va fi permis să intre în rețeaua internă, dacă face parte din traficul unei conexiuni deja stabilite.

CRIPTOGRAFIE

- Criptografia este utilizată pentru a cripta date
 - Criptare – ascundere: pentru a transforma mesaje dintr-o formă în care pot fi înțelese într-o formă neinteligibilă și invers
- Se folosește pentru a furniza următoarele caracteristici ale datelor vehiculate:
 - Autenticitatea datelor
 - Proof of source: pentru a garanta sursa datelor – că vin de la sursa proclamată
 - Confidențialitatea datelor
 - Privacy and secrecy: pentru a garanta caracterul privat al datelor – că nu sunt înțelese de cine nu trebuie
 - Integritatea datelor
 - Datele nu sunt modificate pe parcurs – că au același conținut ca la sursă
 - Proprietatea de „non-repudiation”
 - Datele nu pot fi negate – că vin de la sursă și sursa nu poate nega acest lucru

CRIPTARE SIMETRICĂ

- Aceeași cheie se folosește și pentru criptare și pentru decriptare
 - Sursa și destinația folosesc aceeași cheie: shared key
 - Necesită un schimb sigur al cheii între părți (key exchange). **Dezavantaj:** Riscuri asociate cu compromiterea cheii.
- Rapidă
- Implementată de *DES*, *3DES*, *AES*, *SEAL*
- Se folosește pentru transmisii de date cu volum mare
 - Mail-uri, trafic web securizat, IPsec

CRIPTARE ASIMETRICĂ

- Perechi de chei: publică și privată
 - Cheia publică nu este secretă
 - Cheia privată este secretă
- Mesajele criptate cu cheia publică se decriptează cu cea privată și invers
 - Nu se pot decripta mesajele criptate cu cheia publică folosind cheia publică
 - Nu se pot decripta mesajele criptate cu cheia privată folosind cheia privată
- Proces de criptare/ decriptare mai lent decât cu chei simetrice
- Se folosește pentru transmisii de date cu volum mic
 - Transmisia de chei simetrice
 - Transmisie de semnături digitale, certificate digitale
- Algoritmi: RSA, ECDS

DISTRIBUIREA CHEILOR PRIN PKI

- Public Key Infrastructure – Infrastructura de chei publice
- Bazată pe Certificate Authorities
 - Fiecare browser are o listă de CA de încredere
 - Deține și cheile publice ale fiecăruia
 - După autentificarea unei surse
 - Se generează o cheie publică de către client, se criptează folosind cheia publică din perechea de chei private
 - Se transmite cheia publică către cealaltă parte a comunicației, se decriptează folosind cheia privată din perechea de chei private
 - Acum si sursa și destinația au o cheie shared key pe care o pot folosi pentru transmisia de date cu volum mai mare

CODURI DE AUTENTIFICARE HMAC

- **HMAC** - Hash-based Message Authentication Codes
- Se bazează pe chei simetrice
- Se folosesc pentru verificarea integrității datelor
 - Pe baza datelor se generează o valoare – hash value
 - Se atașează datelor
 - La destinație, se recalculează valoarea
 - Dacă valoarea calculată la destinație este aceeași cu cea transmisă
 - Datele sunt integre – nu au fost modificate în timpul transmisiei
- Algoritmi: MD5, SHA

TLS

- Transport Layer Security
- SSL – depreciat, înlocuit de TLS
- TLS + http -> https pentru trafic web securizat
- Folosește criptografie simetrică pentru criptarea datelor
- Se generează chei simetrice unice pentru fiecare conexiune
- Autentificarea se realizează prin chei publice
- Integritatea datelor se realizează prin HMAC

EXEMPLU STABILIRE CONEXIUNE SIGURĂ

- Presupunem că un client vrea să achiziționeze ceva online de pe emag
- Emag trebuie să se **autentifice** către client
 - Se autentifică utilizând certificatul furnizat de către un CA public de încredere (este listat în browser)
 - Clientul are o listă de CA în care are încredere și o copie a cheilor lor publice
 - Emag generează o pereche de chei: o cheie publică și o cheie privată
 - Cheia privată este păstrată mereu la emag
 - Cheia publică se folosește pentru a solicita certificatul de la CA
 - Se transmite către CA cu o cerere de certificat
 - CA verifică identitatea emag prin altă cale (ex: prin telefonie și întrebări de securitate)
 - Certificatul acordat conține:
 - Cheia publică a emag – disponibilă oricui
 - Domeniul pentru care poate fi folosită
 - Semnătura CA care autentifică certificatul

EXEMPLU STABILIRE CONEXIUNE SIGURĂ - AUTENTIFICARE SITE CĂTRE CLIENT

- Clientul accesează adresa emag
- Emag prezintă certificatul semnat de CA
- Browserul clientului verifică autenticitatea certificatului folosind cheia publică a CA
 - Încrederea în CA se transmite la emag
 - Clientul știe că cel cu care comunică deține certificatul valid pentru emag
 - Nu știe încă faptul că comunică cu emag
 - Oricine ar putea avea certificatul emag, este public, transis oricărui alt client emag
 - Pentru finalizarea autentificării:
 - Clientul transmite un mesaj către emag
 - Emag criptează mesajul folosind cheia sa privată (perechea cheii publice din certificat)
 - Emag transmite mesajul criptat către client
 - Clientul o decriptează cu cheia publică din certificat
 - Dacă mesajul decriptat este același cu cel transmis inițial, emag este autentificat – doar emag are acces la cheia sa privată.

EXEMPLU STABILIRE CONEXIUNE SIGURĂ - TRANSMITERE DATE

- După autentificare, datele ar putea fi transmise în continuare utilizând perechea de chei publice private
 - Clientul criptează datele cu cheia publică
 - Se pot decripta doar cu cheia privată care este doar la emag
- Dar, criptarea asimetrică este înceată
 - Se va folosi doar pentru a face schimb de chei, apoi se va folosi criptarea simetrică
- Clientul generează o cheie pe care o criptează cu cheia publică a lui emag
- Emag o decriptează folosind cheia sa privată
- Cheia astfel creată și distribuită va fi folosită în continuare pentru criptarea datelor cu „PreShared Key”

VPNs

- Rețele private virtuale
- Se bazează pe tunelare
- Avantaje:
 - Protejează datele împotriva interceptării
 - Creează un canal securizat pentru comunicații
 - Ascund adresa IP și locația utilizatorului.
- Utilizări:
 - Acces la rețelele corporative
 - Securizarea conexiunilor Wi-Fi publice
 - Accesarea conținutului restricționat geografic.

IPSEC PENTRU VPN-URI

- IPSec – set de protocoale pentru comunicarea sigură, criptată în rețelele IP
 - Folosit adesea pentru implementarea VPN-urilor
 - Două faze:
 - negocierea cheilor
 - Shimbul de informații de autentificare și pentru criptare
 - ISAKMP – Internet Security Association and Key Management Protocol
 - Definește proceduri de autentificare și comunicații sigure.
 - IKE – Internet Key Exchange
 - Generează chei de criptare și autentificare
 - Transmiterea datelor
 - Pentru transmiterea datelor sunt două metode:
 - AH – Authentication Header
 - Furnizează integritate, autentificare și protecție la atacurile de tip replay
 - ESP – Encapsulating Security Payload
 - Furnizează integritate, autentificare și protecție la atacurile de tip replay + confidențialitate
 - ESP este mai folosit decât AH

VPNs folosind ESP

- Două variante:
 - Prin tunelare
 - Mesajul inițial este încapsulat complet, se adaugă header și trailer în jurul întregului mesaj
 - Prin metoda de transport
 - Se criptează doar partea payload-ul unui mesaj
 - Header-ul IP al mesajului original nu este criptat

UTILIZARE VPN-URI

- Tehnologii de implementare
 - **IPSec**: Utilizat pentru a securiza conexiunile între rețele
 - **SSL/TLS VPN**: Oferă securitate pentru conexiuni de la distanță prin browsere web
 - **WireGuard**: Protocol modern, rapid și simplu pentru conexiuni VPN
 - **L2TP/IPSec**: O combinație între Layer 2 Tunneling Protocol și IPSec
 - **OpenVPN**: Un standard deschis, foarte utilizat

SECURIZAREA DISPOZITIVELOR CISCO

User exec Hostname >	Set limitat de comenzi
Privileged exec Hostname #	Majoritatea comenzilor de monitorizare și debugging
Configurare Hosname(config)#	Modul de configurare pentru interfețe, rutare, etc.

■ Setarea de parole pentru accesul

- Fizic, prin portul consolă
 - Parolă pentru console line
- Remote, prin ssh
 - Parolă pentru vty (virtual terminal line)
- Parolă pentru accesul la nivelul privileged exec
 - Pentru trecerea de la user exec la privileged exec (la introducerea comenzii enable)

Comenzi setare parole

R(config) # line console 0

R(config-line) # **password** *Parola*

R(config-line) # login

R(config) # line vty 0 15

R(config-line) # **password** *Parola*

R(config-line) # login

R(config) # **enable secret** *Parola*
sau

R(config) # enable secret *Parola*

SECURIZAREA DISPOZITIVELOR CISCO

ENABLE PASSWORD ȘI ENABLE SECRET

- Setarea de parole pentru trecerea din user exec în privileged exec
 - De la modul limitat de vizualizare informații pe ruter
 - La modul de monitorizare și debugging
- Parola introdusă prin enable password se salvează în text clar
- Parola introdusă prin enable secret se salvează criptat
 - **Recomandare:** nu se mai folosește comanda enable password
 - **Se folosește doar comanda enable secret**
- Orice parolă introdusă poate fi eliminată cu **no enable password** sau **no enable secret**

Configurare parolă pentru user exec → privileged exec

```
R(config) # enable password Parola  
R(config) # enable secret  
ParolaSecret
```

Parola va fi cerută la introducerea comenzii enable pentru trecerea de la modul user exec → privileged exec

*parolele de enable și enable secret trebuie să difere

SECURIZAREA DISPOZITIVELOR CISCO

CRIPTAREA PAROLELOR IN FISIERUL DE CONFIGURARE

■ Comanda: service password-encryption

```
R# show run
!  
enable secret 5 $1$qwe.....  
enable password Parola  
!  
line con 0  
password ParolaCon  
login  
!  
line vty 0 15  
password ParolaVty  
login  
-----
```



```
R# show run
!  
service password-encryption  
!  
enable secret 5 $1$qwe.....  
enable password 7 0283049...  
!  
line con 0  
password 7 03928475....  
login  
!  
line vty 0 15  
password 7 08304958...  
login  
-----
```

SECURIZAREA DISPOZITIVELOR CISCO

SETARE TIMP EXPIRARE SESIUNE

- Comanda exec-timeout

- Exemplu:

Comanda exec-timeout	
R(config) # line console 0 R(config-line) # exec-timeout 10	Sesiunea se încheie după 10 minute de inactivitate
R(config) # line vty 0 15 R(config-line) # exec-timeout 10 30	Sesiunea se încheie după 10 minute și 30 de secunde de inactivitate
R(config) # line vty 0 15 R(config-line) # no exec-timeout	Sesiunea nu se încheie indiferent de timpul fără activitate

SECURIZAREA DISPOZITIVELOR CISCO CU LISTE DE CONTROL ACCES

- Pentru accesul remote (liniile vty)
 - Mai întâi se crează listă de acces cu adresele permise
 - Apoi se aplică lista de acces pe liniile de acces remote

Exemplu de listă de acces pentru controlul accesului pe liniile vty

```
R(config) # access list 1 permit host adresaIPPermisa
```

```
R(config) # line vty 0 15
```

```
R(config-line) # access-class 1 in
```

- Accesul va fi permis doar de la adresa IP *adresaIPPermisa*

SECURIZAREA DISPOZITIVELOR CISCO CU UTILIZATORI ȘI PAROLE

Comenzi setare parole

```
R(config) # line console 0  
R(config-line) # password Parola  
R(config-line) # login
```

```
R(config) # line vty 0 15  
R(config-line) # password Parola  
R(config-line) # login
```

```
R(config) # enable secret Parola  
sau  
R(config) # enable secret Parola
```

- Prin setarea de parole pentru diferitele moduri de conectare, toți utilizatorii folosesc aceleași parole și au aceleași drepturi de acces
- Sunt 16 niveluri de acces predefinite.
- În mod implicit se folosesc doar 3: 0, 1 și 15
 - 1 – user exec
 - 15 – privileged exec

SECURIZAREA DISPOZITIVELOR CISCO CU UTILIZATORI ȘI PAROLE

Comenzi setare utilizatori

```
R(config) # username admin1 secret Parola
```

```
R(config) # username admin2 secret Parola2
```

* Există și comanda `username user password Pass`, dar nu este recomandată

```
R(config) # line console 0
```

```
R(config-line) # login local
```

```
R(config) # line vty 0 15
```

```
R(config-line) # login local
```

■ Efectul comenzii `login local`:

- Pentru logare se vor folosi conturile locale create cu comanda `username`, nu se vor mai folosi parolele setate cu comanda `password` în modul `config-line`
- La logare se va cere și un nume de utilizator și o parolă

SECURIZAREA DISPOZITIVELOR CISCO CU UTILIZATORI ȘI PAROLE

Comenzi setare utilizatori

```
R(config) # username admin1 secret Parola
```

```
R(config) # username admin2 secret Parola2
```

* Există și comanda `username user password Pass`, dar nu este recomandată

- Sunt 16 niveluri de acces predefinite.
- În mod implicit se folosesc doar 3: 0, 1 și 15
 - 1 – user exec
 - 15 – privileged exec
- La logarea cu username și parolă, nivelul implicit este 1, dacă nu este alt nivel specificat pentru utilizatorul respectiv
- Prin comanda `username` se poate asigna și un nivel de privilegiu

```
R(config) # username admin1 privilege 15 secret Parola
```

- După logare, utilizatorul `admin1` poate rula comenzi cu privilegiul 15
- Privilegiile utilizatorului curent se pot verifica cu comanda `show privilege`

SECURIZAREA DISPOZITIVELOR CISCO CU UTILIZATORI ȘI PAROLE

- Sunt 16 niveluri de acces predefinite.
- În mod implicit se folosesc doar 3: 0, 1 și 15
 - 1 – user exec
 - 15 – privileged exec
- Privilegiile intermediare pot fi asignate anumitor comenzi, pentru a avea un control mai granular asupra drepturilor de rulare a comenzilor

```
R(config) # privilege exec level 10 show ip interface
```

- Drept urmare, un utilizator cu nivelul de privilegii 10 poate rula comanda show ip interface
 - Pentru ca un utilizator să aibă nivelul de privilegii 10, trebuie definit ca având nivelul 10 sau mai sus sau
 - Trebuie să introducă parola de enable pentru nivelul 10 sau mai sus

SECURIZAREA DISPOZITIVELOR CISCO CU UTILIZATORI ȘI PAROLE

```
R(config) # privilege exec level 10 show ip interface
```

- Drept urmare, un utilizator cu nivelul de privilegii 10 poate rula comanda show ip interface
 - Pentru ca un utilizator să aibă nivelul de privilegii 10, trebuie definit ca având nivelul 10 sau mai sus sau
 - Trebuie să introducă parola de enable pentru nivelul 10 sau mai sus

```
R(config) # enable secret Parola
```

- Se setează parola pentru nivelul de enable implicit – nivelul 15

```
R(config) # enable secret level 10 Parola
```

- Se setează parola pentru nivelul specificat – nivelul 10